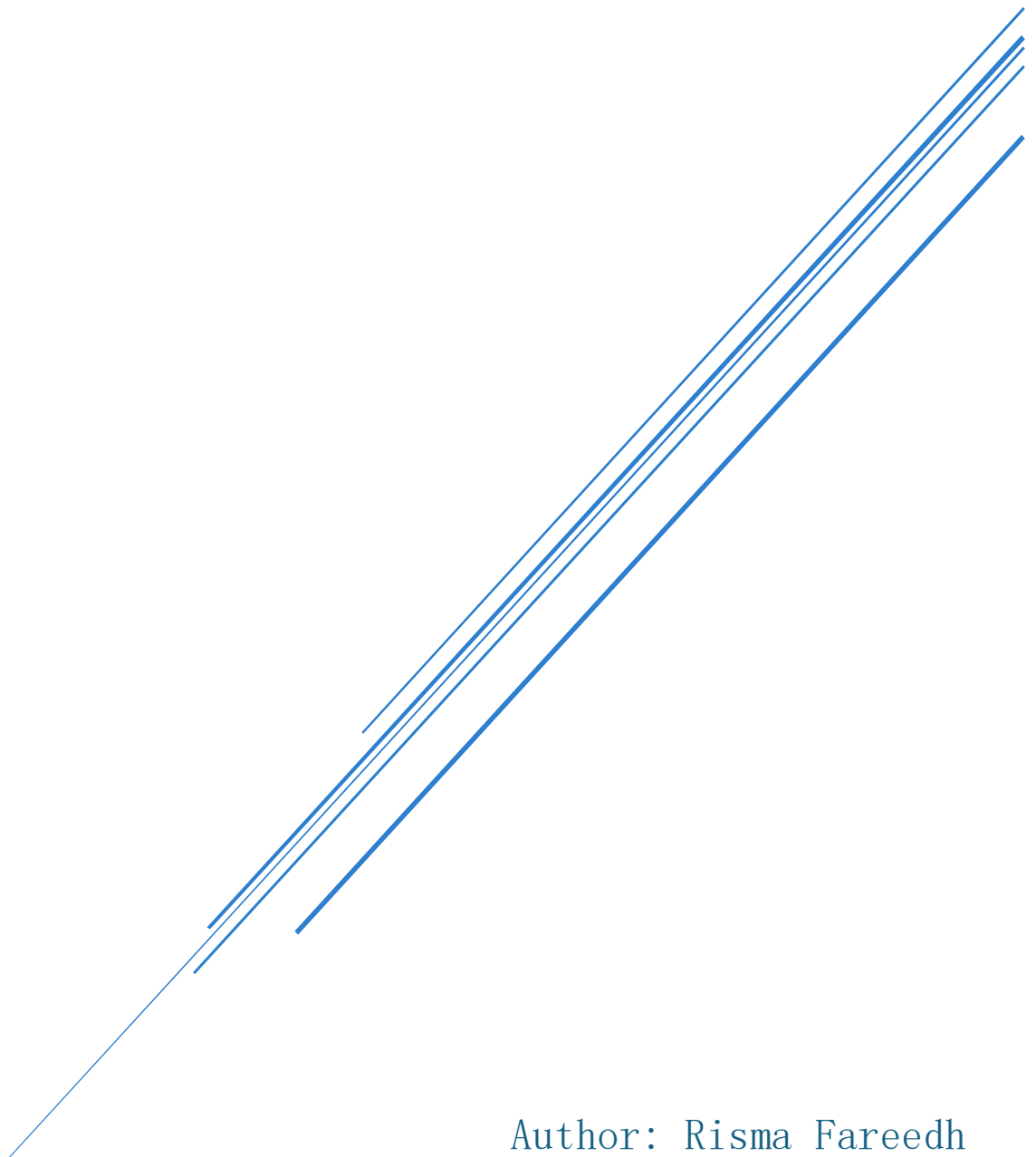


ISO 27001 RISK ASSESSMENT

For Banking Industry



Author: Risma Fareedh
AION Campus

Governance, Risk & Compliance (GRC)

Industry: Banking

Bank Name: Q Bank (fictional)

1. Risk Assessment Methodology

Objective: Identify, assess, and prioritize information security risks to ensure confidentiality, integrity, and availability of Q Bank's assets.

Scope: All systems, processes, locations, and services within the ISMS scope.

Process:

1. **Asset Identification** – List all critical assets, including data, IT systems, processes, and infrastructure.
2. **Threat Identification** – Identify internal and external threats (cyberattacks, human error, natural disasters).
3. **Vulnerability Identification** – Identify weaknesses exploitable by threats.
4. **Risk Analysis** – Evaluate likelihood and impact using a 5x5 risk matrix.
5. **Risk Evaluation** – Prioritize risks (High, Medium, Low) based on rating.
6. **Risk Treatment Recommendation** – Determine appropriate controls (avoid, mitigate, transfer, accept).
7. **Documentation & Review** – Record all risks in the Risk Register, review quarterly or upon major changes.

Risk Scoring: Likelihood (1-5) × Impact (1-5) = Risk Level

2. Risk Register

Risk ID	Asset	Threat	Vulnerability	Likelihood (1-5)	Impact (1-5)	Risk Rating	Existing Controls	Risk Owner	Status
R001	Core Banking System	Unauthorized access	Weak password policy	4	5	20 (High)	MFA, VPN	IT Security	Open
R002	Customer Data	Data leakage	Inadequate encryption	3	5	15 (Medium)	Data encryption in transit	IT Security	Open
R003	ATM Network	Malware infection	Unpatched devices	3	4	12 (Medium)	Patch management, AV	IT Security	Open
R004	HR System	Insider threat	Excessive access rights	2	4	8 (Low)	Role-based access		

3. Risk Treatment Plan

Risk ID	Risk Description	Risk Level	Treatment Option	Controls to Implement	Target Completion	Risk Owner	Status
R001	Unauthorized access to Core Banking	High	Mitigate	Implement MFA, review password policies	31-Oct-2025	IT Security	Open
R002	Data leakage of customer data	Medium	Mitigate	Encrypt sensitive data at rest and in transit	31-Oct-2025	IT Security	Open
R003	Malware on ATM network	Medium	Mitigate	Patch management, AV updates, network segmentation	30-Nov-2025	IT Security	Open
R004	Insider threat on HR system	Low	Accept	Monitor privileged accounts, periodic reviews	Ongoing	HR / IT	Open